

DAY-6 — Users, Groups & sudo

CyberNotes • Detailed Beginner Reference (Improved Edition)

Learning goal: Build a practical, working understanding of **users, groups & sudo**, connect the concept to real cybersecurity work, and practice it safely in a local lab.

Study rule: Understand a command or concept before copying it. Security tools are powerful because they interact with real systems — your practice environment should always be intentionally controlled and authorized.

1. Core Concepts

Core idea: Users, Groups & sudo is a building block for practical cybersecurity. This section explains what each term actually means, where you'll encounter it, and how it connects to the bigger picture.

Why it matters: Security work depends on understanding normal system and network behavior before you can recognize abnormal behavior. This topic connects directly to Linux, networking, web security, monitoring, and troubleshooting — the threads running through this whole 20-day series.

Vocabulary covered: accounts, groups, /etc/passwd, /etc/group, sudo, least privilege, account administration.

Reference	What to remember
<code>id</code>	identity and groups
<code>groups</code>	group membership
<code>sudo -l</code>	view allowed sudo commands
<code>passwd</code>	change password
<code>getent passwd</code>	account database lookup
<code>getent group</code>	group database lookup

2. Concept Explanations

Each term below is explained in plain language, with a note on why it matters for security work. Read these before running any commands.

1. accounts

An account is a distinct identity on the system, each with its own UID, home directory, and privileges. Real systems also have service accounts (like ``www-data`` or ``mysql``) that run background processes with limited rights, separate from human login accounts — a good baseline check is confirming which accounts on a system should actually be able to log in.

2. groups

Groups bundle users together so permissions can be assigned once and shared, rather than configured individually for every account. The ``sudo`` group (or ``wheel`` on some distros) is a critical one to watch —

membership in it effectively grants administrative power.

3. /etc/passwd

`/etc/passwd` is the human-readable database of account records: username, UID, GID, home directory, and login shell (password hashes themselves live in the separately-protected `/etc/shadow`). An unexpected entry here — a new account you didn't create, or an existing account with UID 0 — is a serious red flag during an investigation.

4. /etc/group

`/etc/group` lists every group and its members, and is what `getent group` reads from. Reviewing it periodically helps confirm that only the right people have been added to privileged groups like `sudo`.

5. sudo

`sudo` lets an authorized user run a specific command as another user (usually root) without permanently switching accounts, and every use is logged. `sudo -l` shows exactly which commands you're allowed to run this way — a key tool for both administrators auditing access and attackers looking for a misconfigured rule to exploit.

6. least privilege

Least privilege is the principle that every account, service, and process should have only the minimum access it needs to do its job, no more. It's one of the most important defensive concepts in this entire course: it doesn't prevent every attack, but it drastically limits the damage a compromised account or process can do.

7. account administration

Account administration covers the full lifecycle: creating accounts with appropriate access, reviewing group memberships regularly, disabling accounts promptly when no longer needed, and enforcing password policy. Stale or over-privileged accounts are a very common finding in real security audits.

3. Safe Practical Lab

Step 1. Define the lab target and the exact question you are trying to answer.

Step 2. Run the smallest safe observation or command that can answer that question.

Step 3. Read the output carefully; record important fields, errors, timestamps, and assumptions.

Step 4. Change one variable at a time and compare the result.

Step 5. Write a short conclusion and clean up temporary files or services.

Example lab sequence:

```
id
groups
getent passwd | head
sudo -l 2>/dev/null
```

4. Common Mistakes & Troubleshooting

- Running a command without checking its target, current directory, or privileges.
- Confusing a tool's output with proof of a vulnerability or compromise — output is evidence, not a conclusion.
- Ignoring error messages instead of reading the exact reason for failure.
- Changing several settings at once, making it hard to tell what actually fixed or broke the lab.
- Saving real credentials, tokens, or personal data in practice notes or public repositories.
- Testing a public target just because it's reachable — reachability is never the same as authorization.

Troubleshooting checklist:

- What system am I on?
- What exact command/request did I run?
- What did I expect?
- What happened instead?
- What does the error message say?
- Can I reproduce it in a clean local lab?
- What changed since the last successful attempt?

5. Deep-Dive Questions

Answer these in your own words after finishing the lab — they're designed to check real understanding, not memorization.

Q1. What problem does accounts solve, in your own words?

Notes: _____

Q2. What is the difference between normal behavior and a suspicious observation in this topic?

Notes: _____

Q3. Which command, log, packet, file, or response would you inspect first, and why?

Notes: _____

Q4. What could cause a misleading result or false positive here?

Notes: _____

Q5. How would you document your observation so another learner could reproduce it safely?

Notes: _____

Q6. Which security control reduces the risk associated with this topic?

Notes: _____

6. Revision Checklist

- I can explain users, groups & sudo in my own words.
- I can identify the main terms without looking at the notes.
- I can perform the example in a controlled lab.
- I can interpret the output instead of only copying it.
- I know at least one defensive or troubleshooting use for the concept.
- I can document the result clearly and safely.

7. Safety & Scope

Use these commands and tools only on systems you own, a local virtual machine, a CTF, an intentionally vulnerable application, or a target for which you have explicit written permission.

Keep a written scope: target, allowed actions, time window, and stop conditions. Never scan or test random public systems.

When practicing, save your notes and outputs so you can explain what you observed rather than blindly running commands.

Next step: After Day-6, review your notes and connect this topic to the next subject in the series. The goal is not to memorize commands — it's to understand systems well enough to reason about security.

8. Quick Reference & Personal Notes

Topic: Day-6 — Users, Groups & sudo

Three things I learned:

1. _____
1. _____
1. _____

Commands / concepts to memorize:

- `id` — identity and groups
- `groups` — group membership
- `sudo -l` — view allowed sudo commands
- `passwd` — change password
- `getent passwd` — account database lookup
- `getent group` — group database lookup

My lab result

What I tested: _____

What I observed: _____

What I would investigate next: _____

Final reminder: A strong cybersecurity learner can explain both the offensive concept and the defensive reason for learning it. Keep practice authorized, reproducible, and documented.